

Playbook de Análisis Forense

Guía detallada de investigación y correlación MITRE basada en hallazgos SSH

Generado automáticamente por GoAudit

Fecha: 30/01/2026

Índice

- ✓ 1 — WeakCiphers
- ✓ 2 — ClientAliveConfig
- ✓ 3 — AllowTcpForwarding
- ✓ 4 — HostbasedAuthentication
- ✓ 5 — IgnoreRhosts
- ✓ 6 — MaxAuthTries
- ✓ 7 — MaxSessions
- ✓ 8 — PermitEmptyPasswords
- ✓ 9 — PermitRootLogin
- ✓ 10 — PermitUserEnvironment
- ✓ 11 — MaxStartups

Playbook de Hallazgos

WeakCiphers

Descripción ampliada

El uso de cifrados débiles o CBC en SSH aumenta la probabilidad de ataques MITM y de descifrado parcial del tráfico. Es una vulnerabilidad seria en entornos corporativos.

Importancia defensiva

Los cifrados CBC son débiles frente a ataques conocidos.

Evidencia

```
Se encontró el cipher inseguro: aes128-cbc
```

Explotación del hallazgo

Un adversario puede realizar ataques de downgrade, interceptar tráfico o manipular la negociación del cifrado para obtener información sensible.

MITRE ATT&CK

ID	Técnica	Motivo
T1557	Man-in-the-Middle	Cifrados débiles permiten interceptar tráfico SSH.
T1040	Network Sniffing	Facilita descifrado de sesiones SSH.

Cyber Kill Chain

Fase
Reconnaissance

Weaponization

Exploitation

Indicadores DFIR

Tipo	Detalles
Logs relacionados	• /var/log/auth.log
Artefactos clave	• Negociación de cifrados débiles. • Mensajes de error relacionados con MAC o algoritmos inseguros.

Checklist Forense

- ¿Hay accesos SSH exitosos desde IPs externas o desconocidas?
- ¿Se detectan múltiples intentos fallidos consecutivos?
- ¿Existen modificaciones recientes en authorized_keys?
- ¿Se han creado nuevos usuarios o claves SSH?
- ¿Hay procesos sospechosos ejecutándose bajo root?
- ¿Se han observado sesiones SSH activas fuera de horario?
- ¿Aparecen túneles SSH o conexiones reenviadas inesperadas?

ClientAliveConfig

Descripción ampliada

Valores demasiado altos permiten sesiones persistentes que pueden ser usadas como canales de C2 o mantener conexiones abiertas para actividades maliciosas.

Importancia defensiva

Valores altos retrasan tiempo de detección de sesiones muertas.

Evidencia

```
Línea 12: ClientAliveInterval 600
Línea 13: ClientAliveCountMax 10
```

Explotación del hallazgo

Un atacante puede mantener sesiones abiertas indefinidamente para establecer canales encubiertos de C2.

MITRE ATT&CK

ID	Técnica	Motivo
T1071	C2 Communication	Sesiones largas facilitan canales C2 persistentes.
T1499	Resource Exhaustion	Sesiones sin límite pueden saturar recursos.

Cyber Kill Chain

Fase
Installation
Command & Control

Indicadores DFIR

Tipo	Detalles
Logs relacionados	• /var/log/auth.log
Artefactos clave	• Sesiones inactivas pero persistentes. • Conexiones mantenidas más allá del tiempo esperado.

Checklist Forense

- ¿Hay accesos SSH exitosos desde IPs externas o desconocidas?
- ¿Se detectan múltiples intentos fallidos consecutivos?
- ¿Existen modificaciones recientes en authorized_keys?
- ¿Se han creado nuevos usuarios o claves SSH?
- ¿Hay procesos sospechosos ejecutándose bajo root?
- ¿Se han observado sesiones SSH activas fuera de horario?
- ¿Aparecen túneles SSH o conexiones reenviadas inesperadas?

AllowTcpForwarding

Descripción ampliada

Permitir túneles SSH facilita el pivoting interno, el acceso a servicios que deberían ser privados y la exfiltración de datos sin ser detectado por firewalls.

Importancia defensiva

Evita tunelización no autorizada.

Evidencia

```
Línea 14: AllowTcpForwarding yes
```

Explotación del hallazgo

El atacante crea túneles SSH para pivotar dentro de la red, exfiltrar datos o acceder a sistemas internos.

MITRE ATT&CK

ID	Técnica	Motivo
T1572	Protocol Tunneling	Permite túneles para pivoting interno.
T1090	Proxying	El atacante puede enrutar tráfico a otros sistemas internos.

Cyber Kill Chain

Fase
Exploitation
Installation
Command & Control

Indicadores DFIR

Tipo	Detalles
Logs relacionados	• /var/log/auth.log
Artefactos clave	• Forwarded connections detectadas. • Acceso inesperado a puertos internos desde SSH.

Checklist Forense

- ¿Hay accesos SSH exitosos desde IPs externas o desconocidas?
- ¿Se detectan múltiples intentos fallidos consecutivos?
- ¿Existen modificaciones recientes en authorized_keys?
- ¿Se han creado nuevos usuarios o claves SSH?
- ¿Hay procesos sospechosos ejecutándose bajo root?
- ¿Se han observado sesiones SSH activas fuera de horario?
- ¿Aparecen túneles SSH o conexiones reenviadas inesperadas?

HostbasedAuthentication

Descripción ampliada

La autenticación basada en confianza entre hosts puede ser manipulada por un atacante para moverse lateralmente aprovechando relaciones de confianza obsoletas o inseguras.

Importancia defensiva

Evita autenticación basada en confianza entre hosts.

Evidencia

```
Línea 2: HostbasedAuthentication yes
```

Explotación del hallazgo

El atacante explota relaciones de confianza entre hosts para autenticarse sin contraseña.

MITRE ATT&CK

ID	Técnica	Motivo
T1550	Use of Trusted Relationships	Autenticación basada en confianza entre hosts.
T1078	Valid Accounts	Un atacante puede abusar del trust inter-host.

Cyber Kill Chain

Fase
Exploitation
Lateral Movement

Indicadores DFIR

Tipo	Detalles
Logs relacionados	• /var/log/auth.log
Artefactos clave	• Autenticación basada en host incorrecta. • Accesos desde hosts aparentemente confiables.

Checklist Forense

- ¿Hay accesos SSH exitosos desde IPs externas o desconocidas?
- ¿Se detectan múltiples intentos fallidos consecutivos?
- ¿Existen modificaciones recientes en authorized_keys?
- ¿Se han creado nuevos usuarios o claves SSH?
- ¿Hay procesos sospechosos ejecutándose bajo root?
- ¿Se han observado sesiones SSH activas fuera de horario?
- ¿Aparecen túneles SSH o conexiones reenviadas inesperadas?

IgnoreRhosts

Descripción ampliada

Si el sistema no ignora archivos rhosts, un atacante puede aprovechar configuraciones antiguas para autenticarse sin contraseña.

Importancia defensiva

Los archivos rhosts son altamente inseguros.

Evidencia

```
Línea 3: IgnoreRhosts no
```

Explotación del hallazgo

Si rhosts está permitido, el atacante puede autenticarse desde un host falso configurando un archivo rhosts malicioso.

MITRE ATT&CK

ID	Técnica	Motivo
T1550.003	Exploitation of rhosts	rhosts puede ser utilizado para acceso sin contraseña.
T1078	Valid Accounts	Confianza heredada entre hosts vulnerables.

Cyber Kill Chain

Fase
Exploitation
Lateral Movement

Indicadores DFIR

Tipo	Detalles
Logs relacionados	• /var/log/auth.log
Artefactos clave	• Uso de rhosts para autenticación. • Intentos de login usando mecanismos obsoletos.

Checklist Forense

- ¿Hay accesos SSH exitosos desde IPs externas o desconocidas?
- ¿Se detectan múltiples intentos fallidos consecutivos?
- ¿Existen modificaciones recientes en authorized_keys?
- ¿Se han creado nuevos usuarios o claves SSH?
- ¿Hay procesos sospechosos ejecutándose bajo root?
- ¿Se han observado sesiones SSH activas fuera de horario?
- ¿Aparecen túneles SSH o conexiones reenviadas inesperadas?

MaxAuthTries

Descripción ampliada

Un número excesivo de intentos de autenticación permite a un atacante lanzar ataques de fuerza bruta durante más tiempo sin bloquear la cuenta.

Importancia defensiva

Evita ataques de fuerza bruta.

Evidencia

```
Línea 7: MaxAuthTries 10
```

Explotación del hallazgo

Aumenta la ventana para ataques brute force, permitiendo miles de intentos desde un único origen.

MITRE ATT&CK

ID	Técnica	Motivo
T1110	Brute Force	Aumenta ventana para ataques de credenciales automáticos.

Cyber Kill Chain

Fase
Reconnaissance
Exploitation

Indicadores DFIR

Tipo	Detalles
------	----------

Logs relacionados	• /var/log/auth.log
Artefactos clave	• Múltiples intentos fallidos consecutivos desde una misma IP. • Picos de actividad inusual en autenticación.

Checklist Forense

- ¿Hay accesos SSH exitosos desde IPs externas o desconocidas?
- ¿Se detectan múltiples intentos fallidos consecutivos?
- ¿Existen modificaciones recientes en authorized_keys?
- ¿Se han creado nuevos usuarios o claves SSH?
- ¿Hay procesos sospechosos ejecutándose bajo root?
- ¿Se han observado sesiones SSH activas fuera de horario?
- ¿Aparecen túneles SSH o conexiones reenviadas inesperadas?

MaxSessions

Descripción ampliada

Permitir un número elevado de sesiones simultáneas facilita la ejecución paralela de comandos, exfiltración masiva o múltiples canales C2 dentro del mismo host.

Importancia defensiva

Evita abuso de sesiones múltiples.

Evidencia

```
Línea 19: MaxSessions 50
```

Explotación del hallazgo

Un atacante puede abrir múltiples sesiones para ejecutar tareas paralelas o evadir detección.

MITRE ATT&CK

ID	Técnica	Motivo
T1021	Remote Services	Permite múltiples conexiones SSH simultáneas.
T1105	Exfiltration Over SSH	Puede usarse para múltiples flujos de datos paralelos.

Cyber Kill Chain

Fase
Installation
Command & Control
Actions on Objectives

Indicadores DFIR

Tipo	Detalles
Logs relacionados	• /var/log/auth.log
Artefactos clave	• Varios canales SSH abiertos en paralelo. • Sesiones activas persistentes o fuera de horario.

Checklist Forense

- ¿Hay accesos SSH exitosos desde IPs externas o desconocidas?
- ¿Se detectan múltiples intentos fallidos consecutivos?
- ¿Existen modificaciones recientes en authorized_keys?
- ¿Se han creado nuevos usuarios o claves SSH?
- ¿Hay procesos sospechosos ejecutándose bajo root?
- ¿Se han observado sesiones SSH activas fuera de horario?
- ¿Aparecen túneles SSH o conexiones reenviadas inesperadas?

PermitEmptyPasswords

Descripción ampliada

Permitir inicios de sesión sin contraseña elimina cualquier barrera de autenticación, permitiendo accesos automatizados no autorizados. Representa un riesgo crítico.

Importancia defensiva

Evita sesiones sin contraseña.

Evidencia

```
Línea 6: PermitEmptyPasswords yes
```

Explotación del hallazgo

El atacante solo necesita identificar un usuario sin contraseña para obtener acceso inmediato al sistema.

MITRE ATT&CK

ID	Técnica	Motivo
T1078	Valid Accounts	Cuentas sin contraseña permiten acceso directo.
T1110	Brute Force	Elimina el proceso de autenticación, facilitando accesos automatizados.

Cyber Kill Chain

Fase
Exploitation
Installation

Indicadores DFIR

Tipo	Detalles
Logs relacionados	• /var/log/auth.log
Artefactos clave	• Inicios de sesión sin contraseña. • Usuarios sin contraseña detectados en /etc/shadow.

Checklist Forense

- ¿Hay accesos SSH exitosos desde IPs externas o desconocidas?
- ¿Se detectan múltiples intentos fallidos consecutivos?
- ¿Existen modificaciones recientes en authorized_keys?
- ¿Se han creado nuevos usuarios o claves SSH?
- ¿Hay procesos sospechosos ejecutándose bajo root?
- ¿Se han observado sesiones SSH activas fuera de horario?
- ¿Aparecen túneles SSH o conexiones reenviadas inesperadas?

PermitRootLogin

Descripción ampliada

Habilitar el acceso directo al usuario root permite a un atacante obtener control total del sistema sin requerir escalada de privilegios. Este es uno de los fallos más críticos en cualquier sistema Linux.

Importancia defensiva

Evita accesos directos al usuario root.

Evidencia

```
Línea 5: PermitRootLogin yes
```

Explotación del hallazgo

Un atacante puede intentar credenciales filtradas, débiles o comunes para obtener acceso directo como root, sin necesidad de escalar privilegios.

MITRE ATT&CK

ID	Técnica	Motivo
T1078	Valid Accounts	Acceso directo como root sin necesidad de elevación.
T1110	Brute Force	Vulnerable a intentos automatizados sobre root.
T1021	Remote Services	SSH permite acceso total al sistema como root.

Cyber Kill Chain

Fase
Reconnaissance
Exploitation

Installation
Command & Control

Indicadores DFIR

Tipo	Detalles
Logs relacionados	• /var/log/auth.log • /var/log/secure
Artefactos clave	• Accesos root desde IPs externas. • Modificación de /root/.ssh/authorized_keys. • Cambios sospechosos en archivos de configuración.

Checklist Forense

- ¿Hay accesos SSH exitosos desde IPs externas o desconocidas?
- ¿Se detectan múltiples intentos fallidos consecutivos?
- ¿Existen modificaciones recientes en authorized_keys?
- ¿Se han creado nuevos usuarios o claves SSH?
- ¿Hay procesos sospechosos ejecutándose bajo root?
- ¿Se han observado sesiones SSH activas fuera de horario?
- ¿Aparecen túneles SSH o conexiones reenviadas inesperadas?

PermitUserEnvironment

Descripción ampliada

Permitir que el usuario cargue variables de entorno puede permitir la inyección de rutas o comandos maliciosos ejecutados por el servidor SSH.

Importancia defensiva

Evita carga de configuraciones maliciosas.

Evidencia

```
Línea 4: PermitUserEnvironment yes
```

Explotación del hallazgo

El atacante introduce variables de entorno maliciosas que alteran rutas de ejecución o cargan código inapropiado.

MITRE ATT&CK

ID	Técnica	Motivo
T1059	Command Execution	Variables maliciosas pueden ejecutar código.
T1543	Modify System Processes	Puede manipular el entorno de ejecución de SSH.

Cyber Kill Chain

Fase
Exploitation
Installation

Indicadores DFIR

Tipo	Detalles
Logs relacionados	• /var/log/auth.log
Artefactos clave	• Variables de entorno sospechosas en sesiones SSH. • Cambios en el entorno de ejecución.

Checklist Forense

- ¿Hay accesos SSH exitosos desde IPs externas o desconocidas?
- ¿Se detectan múltiples intentos fallidos consecutivos?
- ¿Existen modificaciones recientes en authorized_keys?
- ¿Se han creado nuevos usuarios o claves SSH?
- ¿Hay procesos sospechosos ejecutándose bajo root?
- ¿Se han observado sesiones SSH activas fuera de horario?
- ¿Aparecen túneles SSH o conexiones reenviadas inesperadas?

MaxStartups

Descripción ampliada

Configuraciones incorrectas pueden permitir ataques DoS mediante creación masiva de conexiones SSH.

Importancia defensiva

Evita DoS mediante conexiones simultáneas.

Evidencia

```
Parámetro no encontrado en sshd_config
```

Explotación del hallazgo

El atacante genera múltiples conexiones simultáneas para saturar SSH y provocar DoS.

MITRE ATT&CK

ID	Técnica	Motivo
T1499	Denial of Service	Valores incorrectos pueden permitir DoS contra SSH.

Cyber Kill Chain

Fase
Exploitation
Denial of Service

Indicadores DFIR

Tipo	Detalles
------	----------

Logs relacionados	• /var/log/auth.log
Artefactos clave	• Excesivas conexiones simultáneas al daemon SSH. • Indicadores de saturación o DoS.

Checklist Forense

- ¿Hay accesos SSH exitosos desde IPs externas o desconocidas?
- ¿Se detectan múltiples intentos fallidos consecutivos?
- ¿Existen modificaciones recientes en authorized_keys?
- ¿Se han creado nuevos usuarios o claves SSH?
- ¿Hay procesos sospechosos ejecutándose bajo root?
- ¿Se han observado sesiones SSH activas fuera de horario?
- ¿Aparecen túneles SSH o conexiones reenviadas inesperadas?

Fin del Playbook

Este documento recoge un análisis avanzado destinado a apoyar investigaciones forenses, threat hunting y respuesta ante incidentes basados en los hallazgos detectados durante la auditoría de seguridad SSH.

Para remediaciones completas y validación posterior, consulte el informe principal generado por GoAudit.